

Práctica optativa: SSH hardening y fail2ban

Objetivo

Reforzar la seguridad del acceso SSH al router y proteger el servicio frente a ataques de fuerza bruta mediante fail2ban.

Escenario

Se utiliza el mismo escenario de la práctica de configuración del router. El hardening y la configuración de fail2ban se realizan en el router.

Nota: Las salidas de comandos se han recortado para mostrar únicamente la información relevante para la práctica.

Configuración de sshd_config

En /etc/ssh/sshd_config se aplicaron los tres cambios solicitados:

```
Port 2222
PermitRootLogin no
PasswordAuthentication no
```

- `Port 2222`: cambia el puerto SSH por defecto.
- `PermitRootLogin no`: desactiva el acceso directo del usuario root por SSH.
- `PasswordAuthentication no`: desactiva la autenticación por contraseña y deja el acceso mediante clave pública.

Antes de reiniciar el servicio se validó la configuración:

```
sergio@router:~$ sudo sshd -t
sergio@router:~$
```

El comando no devolvió errores. Después se reinició SSH:

```
sergio@router:~$ sudo systemctl restart ssh
sergio@router:~$
```

Se comprobó el acceso por el nuevo puerto desde el host:

```
sergio@Sergio-PC:~$ ssh -p 2222 router
Linux router.sergio.org 6.12.107+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.107-1
The programs included with the Debian GNU/Linux system are free software;
```

```
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: Sat Oct 3 14:12:38 2026 from 192.168.122.1

sergio@router:~\$

Instalación de fail2ban

Se instaló fail2ban en el router:

```
sergio@router:~$ sudo apt update
Obj:1 http://deb.debian.org/debian trixie InRelease
Des:2 http://security.debian.org/debian-security trixie-security InRelease [43,4 kB]
Des:3 http://deb.debian.org/debian trixie-updates InRelease [47,3 kB]
Des:4 http://security.debian.org/debian-security trixie-security/main Sources [239 kB]
Des:5 http://security.debian.org/debian-security trixie-security/main amd64 Packages
Des:6 http://security.debian.org/debian-security trixie-security/main Translation-en
Descargados 756 kB en 1s (751 kB/s)
Se pueden actualizar 63 paquetes. Ejecute «apt list --upgradable» para verlos.
sergio@router:~$ sudo apt install fail2ban
```

Configuración de la jail SSH

Se creó el archivo /etc/fail2ban/jail.local:

```
sergio@router:~$ sudo nano /etc/fail2ban/jail.local
sergio@router:~$ cat /etc/fail2ban/jail.local
[DEFAULT]
# IPs que NUNCA banear
ignoreip = 127.0.0.1/8 ::1

[sshd]
enabled = true
port = 2222
filter = sshd
mode = aggressive
logpath = /var/log/auth.log
backend = systemd
maxretry = 3
findtime = 5m
bantime = 2m
sergio@router:~$
```

La jail SSH actúa en el puerto 2222. Se permiten tres intentos fallidos en cinco minutos y se aplica un baneo de dos minutos. Se utiliza `mode = aggressive` para detectar también intentos fallidos de autenticación por clave pública, ya que las contraseñas están deshabilitadas.

Comprobación inicial de la jail:

```
sergio@router:~$ sudo fail2ban-client status
Status
|- Number of jail:1
`- Jail list:sshd
sergio@router:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed:0
|  |- Total failed:0
|  `-- Journal matches:_SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
    |- Currently banned:0
    |- Total banned:0
    `-- Banned IP list:
sergio@router:~$
```

Demostración del baneo

Desde cliente1 se realizaron varios intentos con un usuario inexistente y sin usar una clave pública:

```
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
inexistente@192.168.0.2: Permission denied (publickey).
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
inexistente@192.168.0.2: Permission denied (publickey).
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
inexistente@192.168.0.2: Permission denied (publickey).
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
inexistente@192.168.0.2: Permission denied (publickey).
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
ssh: connect to host 192.168.0.2 port 2222: Connection refused
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
ssh: connect to host 192.168.0.2 port 2222: Connection refused
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
ssh: connect to host 192.168.0.2 port 2222: Connection refused
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
ssh: connect to host 192.168.0.2 port 2222: Connection refused
[sergio@cliente1 ~]$
```

Al principio SSH rechaza la autenticación. Después aparece Connection refused, lo que evidencia que fail2ban ha bloqueado la IP del cliente.

Se comprobó la IP baneada en el router:

```
sergio@router:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed:1
|  |- Total failed:4
|  `-- Journal matches:_SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
    |- Currently banned:1
```

```
| - Total banned:1
` - Banned IP list:192.168.0.100
sergio@router:~$
```

La IP 192.168.0.100, correspondiente a cliente1, quedó baneada.

Expiración del baneo

Tras esperar los dos minutos configurados en bantime, se consultó de nuevo el estado:

```
sergio@router:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
| - Filter
|   | - Currently failed:1
|   | - Total failed:4
|   ` - Journal matches:_SYSTEMD_UNIT=ssh.service + _COMM=sshd
` - Actions
    | - Currently banned:0
    | - Total banned:1
    ` - Banned IP list:
sergio@router:~$
```

La IP ya no aparece en la lista de baneadas. Desde cliente1 se verificó que el router volvía a aceptar conexiones SSH:

```
[sergio@cliente1 ~]$ ssh -p 2222 -o PubkeyAuthentication=no inexistente@192.168.0.2
inexistente@192.168.0.2: Permission denied (publickey).
[sergio@cliente1 ~]$
```

Ya no aparece Connection refused, por lo que el baneo ha expirado. El mensaje Permission denied (publickey) es el esperado debido a la configuración previa PasswordAuthentication no: el router acepta la conexión, pero rechaza la autenticación porque el usuario no existe y no tiene una clave pública autorizada.

Medidas de seguridad

Desactivar root por SSH

Ataque mitigado: ataques de fuerza bruta y de diccionario contra el usuario root.

Motivo: root es un usuario conocido y tiene privilegios de administrador. Al impedir su acceso directo se reduce la superficie de ataque y se obliga a utilizar un usuario normal y, si es necesario, sudo.

Desactivar contraseñas

Ataque mitigado: fuerza bruta, diccionario y uso de contraseñas débiles, reutilizadas o filtradas.

Motivo: solo se aceptan claves públicas. Un atacante necesitaría disponer de la clave privada correspondiente en vez de poder probar contraseñas.

Cambiar el puerto SSH

Ataque mitigado: escaneos y ataques automáticos masivos dirigidos al puerto TCP/22.

Motivo: usar el puerto 2222 reduce los intentos automatizados y el ruido en los registros. No sustituye a las demás medidas, porque un atacante que conozca el puerto puede escanearlo.

fail2ban

Ataque mitigado: ataques de fuerza bruta y de diccionario.

Motivo: fail2ban analiza los registros, cuenta los fallos y bloquea temporalmente la IP que supera el límite configurado. En esta práctica baneó 192.168.0.100 y retiró el bloqueo después de dos minutos.